

Certainly! Below is a **Security Architectural Pattern and Implementation Guidelines** document for **evaluating a third-party vendor offering AI/LLM capabilities**, formatted in the same structure as your last query.

Name

Third-Party Vendor Evaluation for AI/LLM Capabilities

Status

PUBLISHED

Last Revision Date

26 May 2025

Description

This pattern provides a structured security approach for evaluating third-party vendors who provide AI products or services using Large Language Models (LLMs). It ensures that vendors meet company standards in privacy, data handling, model safety, compliance, and operational resilience before integration into company systems or product workflows.

Threat Modeling

When integrating a third-party vendor with LLM capabilities, risks include:

- **Sensitive Data Exposure:** Vendor systems may collect, process, or store sensitive customer or business data.
- **Model Vulnerabilities:** LLMs may produce toxic, biased, or misleading content.
- **Data Retention and Reuse:** Vendor may use submitted data to train or improve their models without consent.
- **API Key Abuse:** Vendor APIs could be misused or compromised.
- **Lack of Security Controls:** Vendor may lack proper controls for authentication, encryption, audit, or incident response.

Security Controls

1. **Vendor Risk Assessment**
 - Perform a comprehensive third-party risk review including questionnaires (e.g., SIG, CAIQ), SOC 2 Type II or ISO 27001 certifications.
 - Review AI-specific controls and responsible AI practices.
2. **Data Protection Agreement (DPA)**
 - Ensure a DPA is signed and reviewed by legal. It must clearly define data ownership, retention, deletion, and jurisdictional processing boundaries.
3. **Usage Restrictions & LLM Purpose**
 - Confirm the vendor **does not use your prompts or data to fine-tune models**, unless explicitly agreed and opt-in.
 - Require clear policy on output filtering, content moderation, and misuse handling.
4. **Security Architecture Review**
 - Evaluate vendor infrastructure, LLM architecture, encryption methods, access controls, and data isolation techniques.
5. **API and Access Security**
 - Enforce secure API integration patterns (TLS 1.2+), API keys scoped to minimal permissions, rate limiting, and request logging.
6. **Incident Response Integration**
 - Require vendor to notify the company of incidents within a defined SLA. Review their incident response policy and past breach history.

Implementation Guidance

1. **Security Due Diligence**
 - Conduct tabletop reviews, security questionnaires, and penetration test result reviews.
 - Evaluate Responsible AI policies: Does the vendor disclose bias handling, model sources, training data governance?
2. **Proof of Concept with Test Data Only**
 - Validate the vendor offering using only non-production/test data.
 - Monitor outputs for hallucination, unsafe language, and performance.
3. **Redlined Contract Reviews**
 - Ensure contracts specify:
 - No data training without consent
 - Right to audit and inspect
 - Model explainability support
 - Termination and data deletion clauses
4. **Integration Patterns**
 - Use proxy/API gateways to mediate calls to vendor LLMs.
 - Encrypt prompts and responses in transit and at rest.

- Log all interactions in a secured audit log for compliance.
 - 5. **Data Classification Alignment**
 - Only allow low-sensitivity or masked data to be sent to external AI/LLM vendors unless reviewed and approved by Data Governance.
-

Testing and Validation

1. **Security Validation**
 - Conduct static and dynamic application security testing (SAST/DAST) on integration points.
 - Perform vulnerability scanning and dependency risk assessments.
 2. **AI Behavior Testing**
 - Test for prompt injection, leakage, hallucination, and safety violations.
 - Use internal adversarial prompts and external red teaming reports.
 3. **Privacy Testing**
 - Confirm that data sent to the vendor cannot be reconstructed, memorized, or extracted by repeated querying.
 - Perform retention and deletion validation.
 4. **Ongoing Monitoring**
 - Continuously monitor API behavior, usage patterns, latency, and failure rates.
 - Set up anomaly detection for unusual or unsafe model responses.
 5. **Annual Re-evaluation**
 - Review vendor's posture annually or upon significant product changes, breaches, or regulatory shifts.
-

Let me know if you'd like a **checklist format**, **vendor scorecard**, or **policy template** to go along with this architectural guideline.